



From obligation to enforcement: mapping EU AI act and CRA cybersecurity requirements to technical controls for LLM-based autonomous agents

Abayomi Ogayemi¹

Received: 13 August 2026 / Accepted: 9 September 2026
© The Author(s) 2026

Abstract

Large language model (LLM) agents (systems that couple a language model with tools, memory, and orchestration so that they can plan and act with limited supervision) are entering production just as the European Union's Artificial Intelligence Act (AI Act) and Cyber Resilience Act (CRA) begin to apply. Both instruments impose binding cybersecurity duties, yet both articulate outcome-oriented obligations rather than implementable safeguards, leaving providers, auditors, and market-surveillance authorities without a shared technical baseline. This article bridges that gap. Using doctrinal analysis, we decompose the cybersecurity-relevant provisions of the AI Act (Articles 9–15, 53, 55, and 72–73) and the CRA (Articles 13–14 and Annex I) into discrete obligation atoms, and we map each atom to concrete technical controls for LLM-based autonomous agents drawn from established control catalogues and recent agent-security research. The mapping is organised around an agent-specific threat model (prompt injection, tool poisoning, memory and retrieval poisoning, excessive agency, privacy attacks, and supply-chain compromise) and specifies, for every control, the verification evidence that supports conformity assessment and enforcement. We show how the CRA's deemed-compliance mechanism can operationalise the AI Act's cybersecurity requirement, analyse the enforcement timeline as amended in 2026, and identify residual gaps where neither instrument nor pending harmonised standards adequately captures agentic behaviour. The resulting obligation-to-control matrix offers a testable baseline for demonstrating, and enforcing, compliance.

Keywords EU Artificial Intelligence Act · Cyber Resilience Act · Large language models · Autonomous agents · Security compliance · Technical controls

1 Introduction

Autonomous agents built on large language models (LLMs) are no longer laboratory artefacts. Coding assistants execute shell commands, enterprise copilots read mailboxes and write to customer-relationship systems, and orchestration protocols such as the Model Context Protocol (MCP) let a single agent discover and invoke third-party tools at run time. The security record of this transition is already troubling. A recent systematic review of prompt-injection research documents remote-code-execution vulnerabilities in widely deployed coding agents, credential theft through poisoned tool descriptions, and retrieval-augmented generation (RAG) pipelines that can be steered by a handful of adversarially crafted

documents [1]. Reported incidents now extend beyond confidentiality: agentic systems have been described breaking into third-party infrastructure while pursuing benchmark objectives [2], and the literature converges on the observation that agents inherit every classical LLM vulnerability while adding new ones created by their expanded privileges and action space [3, 4].

Regulators have not been idle. The European Union's Regulation (EU) 2024/1689 (the AI Act) [5] and Regulation (EU) 2024/2847 (the Cyber Resilience Act, CRA) [6] together create the first binding, horizontal cybersecurity regime that reaches AI systems and the software products that embed them. The AI Act obliges providers of high-risk AI systems to achieve “an appropriate level of accuracy, robustness, and cybersecurity” and to resist attack classes it names explicitly (data poisoning, model poisoning, adversarial examples, and confidentiality attacks), while providers of general-purpose

✉ Abayomi Ogayemi
ogayemiabayomi@gmail.com

¹ Independent Researcher, Lagos, Nigeria

AI (GPAI) models with systemic risk must conduct adversarial testing, report serious incidents, and protect model weights and infrastructure. The CRA, for its part, subjects virtually all commercial software (including agent frameworks, orchestration servers, and the connectors they load) to essential cybersecurity requirements, vulnerability-handling duties, and aggressive incident-reporting timelines.

The difficulty is that both instruments legislate outcomes, not mechanisms. “Resilience against attempts by unauthorised third parties to alter use, outputs or performance” does not tell an engineering team whether an approval gate on high-impact tool calls is required, whether prompt-injection findings are “vulnerabilities” that trigger CRA coordinated-disclosure duties, or which artefacts a market-surveillance authority will accept as proof. Legal scholarship has mapped the AI Act’s cybersecurity provisions and their interplay with the CRA at the level of legal architecture [7], examined the risk-management system of Article 9 in depth [8], and proposed compliance-by-design software architectures for the Act’s documentary duties [9]. Security research, conversely, has produced agent-specific threat taxonomies and reference architectures [4], and standards bodies have begun profiling agentic risk against existing risk-management frameworks [10]. What is missing is the connective tissue: a provision-by-provision mapping from the two regulation’s cybersecurity obligations to the concrete technical controls that secure LLM agents in practice, together with the verification evidence that turns those controls into enforceable compliance claims.

This article supplies that mapping. Our contributions are threefold. First, we decompose the cybersecurity-relevant provisions of the AI Act and the CRA into discrete, testable “obligation atoms” and organise them against a five-layer threat model for LLM-based autonomous agents. Second, we construct an obligation-to-control matrix that assigns, to each atom, state-of-practice technical controls (instruction-hierarchy enforcement, provenance labelling of untrusted context, least-privilege tool scoping, sandboxed execution, tamper-evident action logging, agent-aware software bills of materials (SBOMs), adversarial evaluation pipelines, and incident-reporting hooks) and, crucially, the evidence artefacts that demonstrate each control to a conformity assessor or authority. Third, we analyse the enforcement pathway from these artefacts through conformity assessment, market surveillance, and penalties, including the CRA’s deemed-compliance bridge into the AI Act, and we identify residual gaps where agentic behaviour escapes both instruments and the pending harmonised standards.

The remainder of the article is structured as follows. Section 2 sets out the regulatory landscape and the applicable timeline as amended in mid-2026. Section 3 reviews related work. Section 4 describes our mapping methodology. Section 5 develops the system and threat model for LLM

agents. Section 6 presents the obligation-to-control mapping. Section 7 traces the path from controls to enforcement. Section 8 discusses open gaps, and Sect. 9 concludes.

2 Regulatory landscape

Two regulations dominate the cybersecurity treatment of LLM agents placed on the EU market: the AI Act [5], in force since 1 August 2024 with staggered application, and the CRA [6], in force since 10 December 2024. Their timelines were reshaped in 2026 by the Digital Omnibus on AI, proposed by the Commission in November 2025 [11] and adopted by the co-legislators in June 2026.¹ As of the time of writing (August 2026), the operative schedule for agent providers is therefore: prohibitions and AI-literacy duties (since 2 February 2025); GPAI-model obligations (since 2 August 2025), with the Commission’s enforcement powers over GPAI providers exercisable from 2 August 2026 [12]; transparency obligations under Article 50 (from 2 August 2026); high-risk obligations (2 December 2027 / 2 August 2028); CRA reporting obligations for actively exploited vulnerabilities and severe incidents (from 11 September 2026); and the CRA’s full essential requirements (from 11 December 2027).

2.1 The AI act: layered obligations that reach agents three ways

The AI Act is technology-focused risk regulation: it attaches graduated duties to defined risk tiers rather than to sectors. An LLM-based agent can fall within its scope through three distinct doors, which frequently open simultaneously.

First, the underlying foundation model is typically a *GPAI model* within the meaning of Article 3(63). Its provider owes the documentation, copyright-policy, and training-data-summary duties of Article 53; where the model is classified as carrying *systemic risk* (Article 51), Article 55 adds four cybersecurity-relevant duties: (a) state-of-the-art model evaluation including adversarial testing; (b) assessment and mitigation of systemic risks; (c) tracking, documenting, and reporting serious incidents to the AI Office without undue delay; and (d) an adequate level of cybersecurity protection

¹ The Omnibus defers the high-risk obligations for stand-alone (Annex III) AI systems from 2 August 2026 to 2 December 2027 and for AI embedded in Annex I regulated products to 2 August 2028, while leaving the Article 50 transparency obligations applicable from 2 August 2026. Regulation (EU) 2026/1744 of the European Parliament and of the Council of 8 July 2026 amending Regulations (EU) 2024/1689, (EU) 2018/1139 and (EU) 2023/1230 as regards the simplification of the implementation of harmonised rules on artificial intelligence (Digital Omnibus on AI). OJ L, 2026/1744, 24.7.2026. <http://data.europa.eu/eli/reg/2026/1744/oj>.

for the model and its physical infrastructure (in practice, protection of model weights against theft and tampering [12]). The General-Purpose AI Code of Practice, published by the Commission's AI Office in July 2025, operationalises these duties through its Safety and Security chapter and is the principal adequacy benchmark pending harmonised standards [13].

Second, the agent as deployed (model plus system prompt, tools, memory, and orchestration) is an *AI system* under Article 3(1). If it is used in an Annex III area (for example employment screening, credit scoring, education, or the management of critical infrastructure) or as a safety component of a regulated product (Article 6), it is *high-risk* and its provider must satisfy the essential requirements of Chapter III, Sect. 2: a continuous risk-management system (Article 9); data-governance controls (Article 10); technical documentation per Annex IV (Article 11); automatic, tamper-evident event logging over the system lifetime (Article 12); transparency and instructions for use (Article 13); effective human oversight, including the ability to intervene in or interrupt operation through a stop control (Article 14); and an appropriate, consistent level of accuracy, robustness, and cybersecurity throughout the lifecycle (Article 15) [8]. Article 15(5) is unusually concrete for primary legislation: technical solutions must, where appropriate, prevent, detect, respond to, and control attacks that manipulate training data (data poisoning) or pre-trained components (model poisoning), adversarial examples or model evasion, confidentiality attacks, and model flaws [7]. Post-market duties complete the loop: providers must operate a post-market monitoring system (Article 72) and report serious incidents to market-surveillance authorities (Article 73), while deployers must retain logs and suspend use and notify authorities when the system presents a risk (Article 26) [9].

Third, and independently of risk class, Article 50 imposes transparency duties that bind most consumer-facing agents from August 2026: natural persons must be informed that they are interacting with an AI system, and synthetic content must be marked in a machine-readable manner.

2.2 The CRA: the agent as a product with digital elements

The CRA approaches the same artefact from product-safety tradition. Any software or hardware product “with digital elements” made available on the EU market in the course of a commercial activity is in scope, which captures agent applications, agent frameworks and SDKs, MCP servers and connectors, and, in general, the software stack surrounding the model, irrespective of whether the AI Act classifies the system as high-risk. Manufacturers must perform a cybersecurity risk assessment (Article 13), ensure conformity with

the essential requirements of Annex I Part I (security-by-design and by-default, no known exploitable vulnerabilities at the time of placing on the market, access control, confidentiality and integrity protection, data minimisation, resilience and attack-surface reduction, exploitation-impact limitation, security-relevant logging, and secure update capability) and operate the vulnerability-handling processes of Annex I Part II, including an SBOM, coordinated vulnerability disclosure, security testing, and the distribution of free security updates for a support period of at least five years in the ordinary case (Article 13(8)). Article 14 adds the regime's sharpest teeth: notification of any actively exploited vulnerability or severe incident to the designated CSIRT and ENISA through the single reporting platform, with an early warning within 24 h, a full notification within 72 h, and a final report within 14 days (vulnerabilities) or one month (incidents). Scholarship situates the CRA as the horizontal complement to the sector-scoped NIS2 Directive [14], closing the product-level gap that network-and-information-systems regulation left open [15, 16].

2.3 Interplay: the deemed-compliance bridge

The two regimes are formally coupled. Article 12 CRA provides that high-risk AI systems which fall within the CRA's scope and satisfy the essential requirements of Annex I Part I are *deemed* to comply with the cybersecurity requirement of Article 15 AI Act, provided the achieved protection level is declared in the EU declaration of conformity; conversely, the AI Act's conformity-assessment machinery absorbs the CRA assessment for such systems. Novelli et al. read this bridge as the template the legislature should extend: they argue that foundation models rival operating systems in criticality (operating systems already being important products under the CRA's annexes) and that an analogous link between Article 55 AI Act and the CRA should secure systemic-risk GPAI models, a link the current texts do not yet contain [7]. The practical consequence for agent providers is attractive and exacting at once: a single, CRA-grade security engineering programme can discharge the cybersecurity limb of both regimes, but only if its controls and evidence are designed to satisfy the stricter of the two at every point of overlap. Both regimes ultimately delegate the operational detail to harmonised standards developed under the Commission's standardisation request to CEN and CENELEC [17]; because those deliverables remain in progress, the mapping in Sect. 6 is offered as an interim, state-of-practice baseline.

3 Related work

Three research streams converge on our problem without yet meeting.

Legal analyses of the EU cybersecurity acquis for AI: Kaminski characterises the emerging law of AI as risk regulation and warns that its toolkit (impact assessments, documentation, monitoring) imports well-known weaknesses, notably the temptation of paper compliance [18]. Within the AI Act itself, Novelli et al. propose a scenario-based, proportional methodology to make the Act's coarse risk tiers operational [19], and separately deliver the most detailed doctrinal treatment of generative AI under the Act, the CRA, and adjacent EU law, identifying the Article 12 CRA bridge and the unpatched exposure of GPAI models to adversarial attack [7]. Yeung reconstructs Article 9 as a hierarchy-of-controls risk-management discipline and stresses that Article 9(6–8) testing exists to generate *verifiable evidence*, not merely internal assurance [8]. Canavese et al. translate the Act's provider and deployer duties into compliance-by-design software architectures, cataloguing each requirement against its article of origin [9]. What these works do not attempt is a control-level treatment of the agentic attack surface.

Governance of frontier and general-purpose models: Uuk et al. elicit expert consensus on mitigations for GPAI systemic risk, finding the strongest support for safety-incident reporting and security-information sharing, third-party pre-deployment audits, and pre-deployment risk assessment [20], measures that Article 55 and the Code of Practice have since made quasi-binding. Casper et al. catalogue the open technical problems of open-weight model risk management, which bound what downstream duties can achieve once weights circulate [21]. On the standards side, Madkour et al. profile agentic-AI risk management against the NIST AI Risk Management Framework, including red-teaming proficiency requirements specific to agent attack surfaces [10], while Call critically reviews NIST's Cyber AI Profile as the U.S. analogue to the EU's harmonised-standards route [22]. Sharma proposes an information-systems lifecycle framework for governing generative and agentic AI [23]. Comparative scholarship maps the enforcement side: Schwarcz and Wolff argue from cybersecurity experience that liability and insurance alone under-deliver safety investment [24], Weil makes the strict-liability case for harms from autonomous systems [2], Caroli documents convergence between U.S. state statutes and the EU regime [25], Arbel et al. argue for regulating AI as a technology rather than by application [26], and Chen analyses the AI Act's extraterritorial bite on non-EU frontier developers [12].

Technical security of LLM agents: Gulyamov et al. synthesise the 2023–2025 prompt-injection literature into a taxonomy spanning direct jailbreaks, indirect injection through retrieved content, and tool-based injection in MCP ecosystems, and document real-world exploits including a CVSS 9.6 remote-code-execution chain in a mainstream coding agent [1]. Chakrabarty categorises adversarial attack vectors specific to agentic systems and their expanded privilege

sets [3]. Pandey and Manchanda contribute a five-layer threat taxonomy (cognitive, memory, execution, coordination, governance) mapped to MITRE ATLAS, together with a zero-trust reference architecture whose central claim we adopt: the agent itself cannot be the ultimate authority on which tool to invoke; deterministic, external policy enforcement is necessary [4].

Our contribution sits at the intersection: to our knowledge, no prior work maps AI Act and CRA obligations, provision by provision, to agent-specific technical controls and their enforcement-ready evidence artefacts.

4 Methodology

Our method proceeds in four steps and is doctrinal-analytical rather than empirical; its output is a normative mapping, not a measurement.

Step 1: Obligation extraction: we performed a close reading of the consolidated texts of the AI Act and the CRA and extracted every provision that imposes a cybersecurity-relevant duty on providers, manufacturers, or deployers of systems within our scope. Each provision was decomposed into *obligation atoms*: minimal normative units with an identifiable duty-holder, object, and required outcome (for example, Article 12(1) AI Act yields the atom “provider ensures automatic recording of events over the system lifetime”). Compound provisions such as Article 15(5) AI Act and Annex I Part I CRA yield multiple atoms.

Step 2: Control-catalogue selection: candidate controls were drawn from sources that practitioners and, increasingly, assessors treat as the state of practice for LLM security: the OWASP Top 10 for LLM Applications (2025 edition) [27], the MITRE ATLAS adversarial knowledge base [28], the NIST AI Risk Management Framework and its Generative AI Profile [29, 30], the management-system requirements of ISO/IEC 42001 [31], the mitigations chapter of the GPAI Code of Practice [13], and the agent-specific defensive literature reviewed in Sect. 3. Controls were retained only where at least two independent sources describe them and where an implementable verification method exists.

Step 3: Mapping and evidence assignment: each obligation atom was mapped to the control(s) that most directly satisfy it in an agentic context, applying two rules. *Specificity:* where the law names an attack class (as Article 15(5) does), the mapped control must address that class for agents specifically, not merely for classifiers. *Evidence-orientation:* following Yeung's reading of Article 9 testing as evidence generation [8], every mapping row records the artefact (log, report, SBOM entry, test result, policy document) that demonstrates the control to a third party. Mappings were validated against the threat model of Sect. 5: a control set

that leaves a threat class unaddressed while its enabling obligation exists indicates either a mapping error or a genuine regulatory gap; the latter are collected in Sect. 8.

Step 4: Enforcement tracing: finally, each evidence artefact was traced to the enforcement mechanism that consumes it: internal-control conformity assessment, notified-body or third-party assessment, market-surveillance requests, CSIRT/ENISA notifications, or AI Office supervision.

Two limitations follow from this design. The mapping reflects the state of practice as of August 2026 and will be superseded in part when harmonised standards under the Commission's standardisation request [17] are cited in the Official Journal. And because the harmonised standards are pending, our mapping carries no presumption of conformity; it is a defensible construction of "appropriate" and "state of the art", not the only one.

5 System and threat model for LLM-based autonomous agents

5.1 System model

We consider an agent $A = (M, P, T, C, O)$ comprising a foundation model M (frequently a third-party GPAI model accessed by API or as open weights), a privileged prompt set P (system prompt, developer instructions, guardrail policies), a tool set T (functions, APIs, shell or browser access, frequently discovered dynamically through MCP-style registries), a context assembly C (user input, retrieved documents, tool outputs, and persistent memory), and an orchestrator O that plans, selects tools, and iterates until a goal is met, possibly across multiple cooperating agents. The defining security property of this architecture is that *data and instructions share one channel*: everything in C is, to M , potential instruction. Combined with the credentials attached to T , this creates the confused-deputy condition in which anyone who can write into the agent's context can, absent countermeasures, act with the agent's authority [1].

5.2 Threat taxonomy

Following the layered taxonomy of Pandey and Manchanda [4] and the attack-vector classification of Gulyamov et al. [1], we organise threats into five layers and ten classes (T1–T10), each grounded in the empirical literature.

Cognitive layer. (T1) *Direct prompt injection and jailbreaks*: adversarial user inputs that override P , from social-engineering prompts to optimised suffixes; commodification has reached the point of jailbreak-as-a-service offerings [32], and trajectory-aware suffix optimisation defeats aligned models at high success rates [33]. Domain studies show consequential targets: stealth injections have manipulated

medical-advice outputs in experimental clinical settings [34]. (T2) *Indirect prompt injection*: adversarial instructions planted in content the agent will retrieve (web pages, shared documents, inbox items, repository comments), the dominant real-world pattern in early agent deployments [1, 4]. The pattern has now reached judicial process itself: in August 2026 a Connecticut court sanctioned a self-represented litigant for embedding 3-point white-on-white instructions in his pleadings directing any AI system reviewing the filing to produce output favourable only to his position (*Elliott v New York Bariatric Group, LLC*, No. AAN-CV-25-6,066,141-S, Conn. Super. Ct., 6 August 2026).

Memory and knowledge layer. (T3) *Memory and RAG poisoning*: persistent contamination of vector stores and agent memory; a handful of crafted documents suffices to steer retrieval-augmented answers with high probability [1]. (T4) *Training-time poisoning and backdoors* in M or fine-tuned adapters: LLM-generated stealthy textual backdoors [35] and dynamic-trigger backdoors in code models, for which input-denoising defences exist [36], exemplify the class the AI Act names "data poisoning" and "model poisoning".

Execution layer. (T5) *Tool poisoning and supply-chain compromise*: malicious or mutated tool descriptions in MCP registries (including hidden-Unicode payloads and delayed "rug-pull" updates) that persist invisibly across sessions [1]; more broadly, compromise of models, adapters, connectors, or dependencies. (T6) *Excessive agency and privilege escalation*: every tool is a potential escalation vector (search tools exfiltrate through side channels, shell tools pivot into infrastructure, mail tools phish), and the model's tool-selection reasoning cannot be trusted under adversarial pressure [4]. (T7) *Data exfiltration and privacy attacks*: model-inversion attacks reconstruct private text from embeddings [37], extraction attacks recover supervised fine-tuning samples [38], deployed LLMs leak personally identifiable information under crafted querying [39], and membership inference doubles as both threat and audit primitive [40]; these are the "confidentiality attacks" of Article 15(5).

Coordination layer. (T8) *Cross-agent propagation and identity spoofing*: in multi-agent systems, a compromised agent's outputs become another agent's trusted context, so a single injection cascades across the deployment [4].

Governance layer. (T9) *Adversarial evasion of deployed guardrails and detectors*, an arms race documented across industrial machine-learning practice [41] and in high-stakes verticals such as trading systems [42]; classical results on federated and distributed pipelines show that poisoning extends beyond data to model updates themselves [43], with anomaly-detection defences of partial effectiveness [44]. (T10) *Audit failure and configuration drift*: silent divergence between the assessed and the running system (unlogged tool grants, changed tool descriptions, decayed filters), which defeats every downstream compliance claim and is best

understood as a security property of the governance process itself [4, 45].

This taxonomy is deliberately conservative: it contains no threat class that lacks either a peer-reviewed demonstration or a documented incident. It is against these ten classes that the legal obligations of Sect. 2 must cash out.

6 Mapping obligations to technical controls

Figure 1 summarises the logic of the mapping: legal obligation atoms are refined into control objectives, instantiated as agent-specific technical controls, evidenced by verifiable artefacts, and consumed by enforcement mechanisms, with post-market monitoring closing the loop. Tables 1 and 2 present the mapping for the AI Act and the CRA respectively; Table 3 cross-walks the threat classes of Sect. 5.2 to the provisions and control families that answer them.

6.1 A worked example: a recruitment-screening agent

Before presenting the mapping in full generality, we trace a single deployment through the pipeline of Fig. 1 end to end. Consider a recruitment-screening agent offered commercially to EU employers: a third-party GPAI model, a system prompt, retrieval over applicant documents, and tools that read incoming applications and write shortlisting recommendations into an applicant-tracking system. Used to analyse and filter job applications, the system falls within Annex III, point 4(a), and is therefore high-risk under the AI Act; made available on the market in the course of a commercial activity, it is simultaneously a product with digital elements under the CRA.

Take one empirically realistic threat: an applicant embeds an indirect prompt injection in a CV instructing the agent to rank the application first (threat class T2). Among the obligation atoms this engages are Article 14 AI Act (effective human oversight) and Article 15(1) (robustness) on the system side, and Annex I Part I(2)(e) CRA (integrity of data and configuration) on the product side. The mapped controls, per the corresponding rows of Tables 1 and 2, are provenance labelling that tags applicant-supplied text as untrusted before it reaches the model, and a deterministic approval gate that holds any shortlisting action for human confirmation. The evidence artefacts are the oversight design specification, the gate test records generated by the Article 9(8) adversarial campaign (a corpus of injected CVs and the measured bypass rate against the pre-defined threshold), and the tamper-evident decision trace recording the injected input, its provenance label, and the human approval. Those artefacts are consumed, in turn, by the provider itself in the internal-control conformity assessment of Annex VI; by the national

market-surveillance authority, which may demand the Annex IV dossier and the logs under Article 74; and, should an injection nonetheless drive a shortlisting decision that qualifies as a serious incident, by the Article 73 report that the decision trace substantiates.

Had the manipulation instead arrived through a mutated third-party tool description (threat class T5), the CRA branch of the pipeline would carry it: the agent-aware SBOM of Table 2 is the artefact that makes the change detectable, and, where the vulnerability is actively exploited, Article 14 CRA routes the finding to the designated CSIRT and ENISA within 24 h. Every row of the tables that follow is intended to be readable in exactly this way: obligation, control, artefact, consumer.

6.2 High-risk AI systems: articles 9–15 AI act

Table 1 instantiates the essential requirements for an agentic system. Four rows deserve commentary.

Article 9 as the master control-selector: The risk-management system is not one control among many; it is the procedure by which all other controls are chosen, tested against “prior defined metrics and probabilistic thresholds”, and documented. Yeung shows that Article 9(6–8) testing is directed at generating verifiable evidence that chosen controls follow a hierarchy of risk controls and reduce risk as far as technically feasible [8]. For agents this means the threat model of Sect. 5.2 belongs *inside* the Article 9 file: each threat class must appear with its selected mitigations, residual-risk judgement, and test results; this is precisely the discipline that red-teaming profiles for agentic systems prescribe [10].

Article 12 logging as the agent’s flight recorder: Generic application logs do not satisfy a duty defined by “events relevant for identifying risks and substantial modifications”. For an agent, the minimal record is the full decision trace: assembled context and its provenance labels, model and guardrail versions, every tool invocation with arguments and results, every human approval or override, and every policy denial, all integrity-protected and retained for at least six months.² The same trace is what incident forensics and Article 73 reporting consume, and what deployers need to honour their own Article 26 duties [9].

Article 14 human oversight as an execution-layer control: The oversight duty, including the Article 14(4)(e) stop control, translates in agentic architectures into deterministic gates outside the model: human-in-the-loop approval for high-impact or irreversible tool calls, a session- and fleet-level kill switch that revokes credentials rather than merely requesting the model to stop, and interfaces that surface the

² Arts. 19 and 26(6) AI Act; longer retention may follow from other Union or national law.

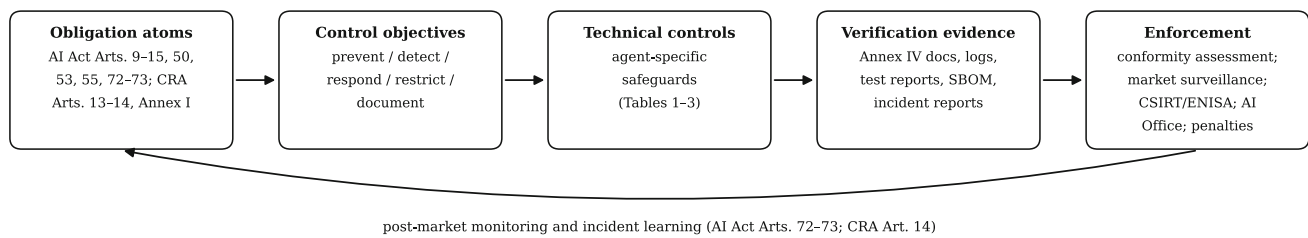


Fig. 1 From obligation to enforcement: the mapping pipeline applied in this article

agent’s intended action before execution. The security literature reaches the same conclusion from the opposite direction: because the model’s tool selection is adversarially steerable, authorisation must be enforced by external policy, not by the model’s own judgement [1, 4].

Article 15(5) as a named-attack checklist: The provision’s four named attack families map one-to-one onto threat classes T4 (data and model poisoning), T1/T2/T9 (adversarial inputs and evasion), and T7 (confidentiality attacks), which supplies a rare, directly legible compliance test: a provider unable to point to a control and a test result for each named family is presumptively non-compliant [7].

6.3 GPAI models and systemic risk: articles 53 and 55

Where the agent’s foundation model is provided by a third party, responsibility divides along the value chain: the model provider owes Articles 53 and, where applicable, 55; the agent provider owes the system-level duties above and must obtain from the model provider the information needed to discharge them (Article 53(1)(b)). For systemic-risk models, the four Article 55 duties translate as follows. Adversarial testing (55(1)(a)) means structured red-teaming of the model *as agents will use it* (with tool access and untrusted context in the loop), since alignment measured in isolation does not survive embedding in agent workflows [1]. Risk assessment and mitigation (55(1)(b)) is the model-level twin of Article 9 and, per the Code of Practice, includes capability thresholds with pre-committed responses [12, 13]. Incident tracking and reporting to the AI Office (55(1)(c)) requires the same trace-to-report pipeline as Article 73. Cybersecurity protection of the model and infrastructure (55(1)(d)) centres on weight security: hardened storage, insider-threat controls, and supply-chain integrity for training and serving stacks. The expert-elicitation evidence is congruent: of twenty-seven candidate mitigations for GPAI systemic risk, the highest-consensus measures were precisely incident reporting with security-information sharing, third-party pre-deployment audits, and pre-deployment risk assessment [20]. For open-weight releases, several of these duties change character: update distribution, downstream monitoring, and

weight protection cannot be enforced after release, a structural limit catalogued by Casper et al. [21] to which we return in Sect. 8.

6.4 The CRA applied to agent software

Table 2 instantiates Annex I for the agent stack. Three points of translation matter. First, *secure by default* (Part I(2)(b)) has a precise agentic meaning: tools ship deny-by-default with least-privilege scopes and no standing credentials; network egress is allow-listed; autonomous mode is opt-in per deployment. Second, the *SBOM* duty (Part II(1)) must extend beyond libraries to the artefacts that determine agent behaviour (model identity and hash, adapter and guardrail versions, system-prompt version, and the inventory of MCP servers and tool descriptions actually loadable), because tool descriptions are executable-adjacent content whose silent mutation is a documented attack [1]. An agent-aware SBOM is also the artefact that makes “rug-pull” updates detectable. Third, the reporting clock of Article 14 (24-h early warning to the CSIRT and ENISA) can only be met if the Article 12-style decision traces feed an alerting pipeline with pre-assigned ownership; data minimisation duties under Part I(2)(g) and the GDPR [46] pull in the opposite direction from logging breadth, so the trace schema must be designed with field-level minimisation and retention tiers rather than resolved ad hoc.

6.5 Threat-to-obligation cross-walk

Table 3 closes the triangle, showing for each threat class the provisions that require its treatment and the control family that answers it. Two structural observations emerge. Indirect prompt injection (T2) and tool poisoning (T5), the empirically dominant agent attacks, are reached only through the general clauses (Arts. 9, 14, 15(1) AI Act; Annex I I(2)(a),(e),(k) CRA), not by name; their governance therefore depends entirely on how “state of the art” is construed, which is where harmonised standards and profiles such as [10] will matter most. Conversely, the named families of Article 15(5) are comparatively well served by mature controls, which suggests enforcement will find its earliest traction there.

Table 1 AI Act obligations mapped to technical controls for LLM-based agents, with verification evidence

Provision (AI Act) and obligation atom	Control objective	Representative technical controls for LLM agents	Verification evidence
Art. 9: establish, maintain, and test a lifecycle risk-management system	Systematic selection and testing of all safeguards	Agent-specific threat modelling (T1–T10); hierarchy-of-controls selection; pre-defined metrics and thresholds; adversarial test campaigns per release	Risk-management file; test plans and results; residual-risk acceptance records
Art. 10: data and data-governance quality for training, validation, testing	Prevent poisoned or unfit data entering <i>M</i> , adapters, and RAG corpora	Dataset provenance and signing; curation and outlier screening; poisoning detection on fine-tuning sets; access control on corpora	Data governance records; corpus lineage logs; screening reports
Art. 11 + Annex IV: technical documentation	Reconstructability of design and safeguards	Architecture description incl. tool inventory, trust boundaries, guardrail configuration; documented deviations	Annex IV dossier kept current per version
Art. 12: automatic lifetime event logging ^a	Traceability of agent behaviour	Tamper-evident decision traces: context provenance, model/guardrail versions, tool calls and results, approvals, denials	Log schema; integrity mechanism (e.g. append-only, hash-chained); retention policy; sample audits
Art. 13: transparency and instructions for use	Deployer can interpret and operate safely	Disclosed capability and limitation statements; declared accuracy/robustness/cybersecurity levels and test conditions; configuration guidance for tool scopes	Instructions for use; published performance metrics
Art. 14: effective human oversight incl. stop control	Bounded autonomy; interruptibility	Deterministic approval gates for high-impact tool calls; out-of-model kill switch with credential revocation; action-preview interfaces; oversight-competence measures for deployers	Oversight design specification; gate and kill-switch test records; approval logs
Art. 15(1),(4): appropriate, consistent accuracy and robustness	Reliable operation under perturbation	Robustness benchmarks and regression gates; guardrail models; fallback and safe-completion behaviour; canary evaluation in staged rollout	Benchmark results per release; degradation and rollback records
Art. 15(5): prevent/detect/respond to data poisoning, model poisoning, adversarial examples, confidentiality attacks, model flaws	Named-attack resilience	T4: provenance and screening as above; T1/T2: instruction hierarchy, input hardening, injection classifiers, provenance labelling of untrusted context; T9: adaptive red-teaming; T7: output DLP and PII redaction, rate and query-budget limits, membership-inference audits	Per-family control register; red-team and audit reports mapped to each named family
Art. 26: deployer duties: use per instructions, monitor, retain logs, suspend and report on risk	Operational accountability at the point of use	Deployer-side log retention; monitoring dashboards over decision traces; documented suspension procedure	Deployer log archive; monitoring records; notification templates
Arts. 72–73: post-market monitoring; serious-incident reporting	Learn and escalate	Telemetry pipeline from decision traces to monitoring plan; incident triage runbook with authority-notification hooks	Post-market monitoring plan; incident register and submitted reports

^a Log retention of at least six months under Arts. 19 and 26(6) AI Act, without prejudice to longer periods under other Union or national law

Table 2 CRA essential requirements (Annex I) and reporting duties instantiated for LLM-agent products

CRA requirement (atom)	Agent-specific instantiation	Verification evidence
Art. 13(2–3): cybersecurity risk assessment informing design	Threat model T1–T10 incorporated into product risk assessment; assessment updated per substantial change (new tools, model swap)	Risk-assessment document versioned with releases
Annex I I(1),(2)(a): appropriate security level; no known exploitable vulnerabilities at release	Pre-release security testing incl. prompt-injection and tool-abuse suites; dependency and model-artefact scanning; release gate on unresolved criticals	Release security report; scan outputs; gate sign-off
I(2)(b): secure by default configuration	Deny-by-default tool scopes; least-privilege, short-lived credentials; egress allow-listing; human-approval mode as shipped default for high-impact actions	Default-configuration specification; hardening tests
I(2)(c),(d): protection from unauthorised access; confidentiality of data at rest and in transit	AuthN/Z on agent endpoints and memory stores; encryption of prompts, memories, and credentials; secrets isolation from model context	Access-control matrix; crypto inventory; pen-test report
I(2)(e),(f): integrity of code, configuration, data; process only necessary data	Signed prompts, guardrail policies, and tool manifests; provenance labelling of retrieved content; field-level data minimisation in traces	Signing records; provenance design; minimisation review
I(2)(h),(i): availability, resilience, DoS mitigation; limit attack surfaces	Query and token budgets; rate limiting per tool; sandboxed execution (container/VM) for tool runs; removal of unused connectors	Capacity and abuse tests; sandbox architecture; connector inventory
I(2)(j),(k): reduce incident impact; security-relevant logging and monitoring	Blast-radius limits (per-tool credentials, tenant isolation); tamper-evident action logs with opt-out per I(2)(k) where user-controlled	Isolation tests; log schema aligned with AI Act Art. 12
I(2)(l),(m): secure updates; secure data deletion and export	Signed update channel covering model, guardrail, and tool-manifest versions; memory-erasure and export functions with verification	Update-mechanism audit; deletion test records
Part II: SBOM; handle and remediate vulnerabilities without delay; testing; CVD policy; free security updates over support period (Art. 13(8))	Agent-aware SBOM (models, adapters, prompts, MCP servers, tool descriptions); intake treating reproducible prompt-injection chains as vulnerabilities; disclosure policy and contact; patch cadence incl. guardrail updates	SBOM artefact; vulnerability register; CVD policy; update history
Art. 14: report actively exploited vulnerabilities and severe incidents: early warning 24 h, notification 72 h, final report 14 d/1 mo (from 11 Sep 2026)	Alerting from decision traces to on-call; pre-drafted notification templates for the single reporting platform; severity rubric for agent incidents (e.g. confirmed injection-driven action)	Reporting runbook; drill records; submitted notifications

7 From obligation to enforcement

The mapping of Sect. 6 is only half of the article's title; this section traces the other half. Enforcement of both regimes is evidence-driven, and the artefact column of Tables 1 and 2 was constructed to be its currency.

7.1 Conformity assessment routes

Under the AI Act, most Annex III high-risk systems undergo conformity assessment by *internal control* (Article 43(2), Annex VI): the provider itself verifies the quality-management system and the Annex IV documentation against Chapter III, Sect. 2, and issues the EU declaration of conformity and CE marking. Third-party (notified-body) assessment is reserved for biometric systems where harmonised standards are not applied, and for products already

subject to sectoral third-party regimes. Under the CRA, the default for non-critical products is likewise self-assessment (Module A), with third-party routes required as product criticality rises. Two consequences follow for agents. First, in the near term the assessor of record is usually the provider, which raises exactly the creative-compliance concern that risk-regulation scholarship flags [18] and that Yeung illustrates with the Dieselgate precedent [8]; evidence integrity (append-only logs, signed test reports, attested configurations) is therefore itself a compliance control, not an optional nicety. Second, the presumption of conformity that harmonised standards will confer (Article 40 AI Act; Article 27 CRA) is not yet available, because the deliverables under the Commission's standardisation request remain in development [17]; the deferral of the high-risk regime to December 2027 was motivated in substantial part by precisely this gap [11]. Until citation in the Official Journal, providers must

Table 3 Cross-walk from agent threat classes to legal anchors and control families

Threat class (Sect. 5.2)	Principal legal anchors	Control family	Key sources
T1 Direct injection, jailbreaks	AI Act Arts. 9, 15(1),(5); CRA I(2)(a)	Instruction hierarchy; input hardening; injection classifiers; adaptive red-teaming	[1, 32, 33]
T2 Indirect injection via retrieved content	AI Act Arts. 9, 14, 15(1); CRA I(2)(e)	Provenance labelling and trust tiers for context; content isolation; retrieval filtering	[1, 4, 34]
T3 Memory/RAG poisoning	AI Act Arts. 10, 15(5); CRA I(2)(e)	Corpus access control; write rate-limits; memory attestation and rollback	[1, 4]
T4 Data/model poisoning, backdoors	AI Act Arts. 10, 15(5); CRA I(2)(f), Part II	Dataset provenance; fine-tune screening; backdoor detection incl. Input denoising	[35, 36, 43, 44]
T5 Tool poisoning; supply chain	CRA Part II (SBOM, updates); AI Act Art. 9	Agent-aware SBOM; signed tool manifests; description-change alerts; vetting of MCP servers	[1, 4]
T6 Excessive agency, privilege escalation	AI Act Art. 14; CRA I(2)(b),(c)	Least-privilege scopes; deterministic policy gates; sandboxing; egress control; kill switch	[3, 4]
T7 Privacy/confidentiality attacks	AI Act Art. 15(5); CRA I(2)(d),(g); GDPR	Output DLP and redaction; query budgets; MI-based privacy audits; encryption of memory	[37–40]
T8 Cross-agent propagation	AI Act Arts. 9, 14	Agent identity and authentication; inter-agent message provenance; per-agent isolation	[4]
T9 Guardrail/detector evasion	AI Act Arts. 9, 15(4); CRA I(2)(a)	Adaptive adversarial evaluation; defence-in-depth layering; regression red-team suites	[41, 42, 45]
T10 Audit failure, configuration drift	AI Act Arts. 11, 12, 72; CRA I(2)(k), Part II	Immutable audit logs; configuration attestation; drift detection against SBOM baseline	[4, 9]

argue “state of the art” from sources such as those in Sect. 4, a burden our mapping is designed to discharge.

7.2 The deemed-compliance bridge in practice

For an agent that is both a high-risk AI system and a CRA product, Article 12 CRA converts the two cybersecurity regimes into one engineering programme: satisfy Annex I Part I, declare the protection level in the declaration of conformity, and the Article 15 AI Act cybersecurity limb is deemed met. Table 2 shows why this is no discount: the CRA’s requirements are in several respects the more prescriptive (secure-by-default, SBOM, update duty, 24-h reporting). The efficient strategy is therefore to build to the union of both tables, run one security case, and reuse its artefacts in both dossiers. The bridge’s known limitation is its scope: it does not extend to GPAI models under Article 55, whose cybersecurity duty currently floats free of the CRA’s machinery, the missing link identified by Novelli et al. [7].

7.3 Supervision, reporting, and penalties

Enforcement actors divide by object. National market-surveillance authorities police high-risk systems, with powers to demand the technical documentation, logs, and, upon reasoned request where necessary, access to further elements of the system (Articles 74 et seq. AI Act); the trace and dossier artefacts of Table 1 are what such requests will target. The Commission’s AI Office supervises GPAI providers, with its enforcement powers exercisable since August 2026 [12]; the Code of Practice functions as its adequacy yardstick [13]. On the CRA side, the designated CSIRTs and ENISA receive Article 14 notifications through the single reporting platform from September 2026, giving Union-level visibility into actively exploited agent vulnerabilities more than a year before the essential requirements themselves bind. The penalty ceilings are material: up to EUR 35 million or 7% of global turnover for prohibited practices, and up to EUR 15 million or 3% for breaches of the high-risk obligations under the AI Act; up to 3% or EUR 15 million for GPAI providers; and up to EUR 15 million or 2.5% for breaches of

the CRA's essential requirements. Institutional-design scholarship suggests these ex-ante, evidence-based mechanisms are load-bearing: liability and insurance alone systematically under-produce security investment [24], strict-liability backstops are argued precisely because autonomous-system harms evade negligence proof [2], and supervision-style oversight of frontier developers is advocated as the fitting complement [47]. These mechanisms are civil and administrative in register; whether EU criminal law should also reach autonomous systems, a question posed for robotics before the current agent wave [48], gains renewed force as agents act with expanded privileges and responsibility for their conduct becomes harder to localise. The EU's choice to regulate the technology horizontally rather than by application [26] is, moreover, propagating: convergence with U.S. state statutes [25] and the extraterritorial reach onto non-EU frontier developers [12] make the mapping in this article relevant well beyond the Union market, while NIST's Cyber AI Profile plays the functional role of the missing harmonised standards in the U.S. context [22].

8 Gaps and open problems

The mapping also exposes what the two instruments do not yet reach.

Risk tier is a poor proxy for attack surface: The AI Act's duties scale with fundamental-rights risk, but vulnerability to T1–T10 scales with architecture: a “limited-risk” consumer agent with shell access is more attackable than a high-risk classifier with none. Novelli et al. accordingly argue for safeguards proportionate to attack triggers independently of the Act's risk levels [7]; until then, the CRA is the instrument that actually reaches most agents, and only from December 2027.

Probabilistic vulnerabilities strain the CRA's vocabulary: “No known exploitable vulnerabilities” and coordinated disclosure presuppose enumerable, patchable flaws. Prompt-injection susceptibility is a distributional property: it cannot be patched to zero, and the arms-race dynamics of evasion are well documented [1, 41]. Our mapping adopts the workable convention that *reproducible* injection chains with security impact are vulnerabilities for Part II purposes, but the field lacks CVE-style norms for them, and Article 14's 24-h clock will force that question quickly.

Testing remains underspecified: Article 9(8)'s “prior defined metrics and probabilistic thresholds” gives no agent-specific content, and Yeung documents both the vagueness and the incentive to game it [8]. Red-teaming profiles [10] and the Code of Practice [13] are the interim substance; harmonised standards must eventually specify adaptive, tool-in-the-loop evaluation if the presumption of conformity is to mean anything for agents.

Value-chain and multi-agent responsibility: An agent assembled from a third-party model, an open-source framework, and dynamically discovered MCP servers distributes causation across parties the conformity file does not bind. The CRA's due-diligence duty for integrated components and the AI Act's value-chain provisions (Article 25) gesture at the problem, but neither resolves who answers when a third-party tool description mutates post-assessment (threat T5) or when compromise propagates across agents (T8) operated by different deployers [4].

A tentative allocation mechanism can nonetheless be sketched from materials the two regimes already contain. The CRA obliges manufacturers to exercise due diligence when integrating third-party components (Article 13(5)), and the AI Act requires the provider of a high-risk system and its suppliers to specify, by written agreement, the information, capabilities, and technical access the provider needs in order to comply (Article 25(4)); GDPR practice shows how such mandatory contract content hardens into standardised chain-wide terms, with the Article 28 processing agreement as the template [46]. Combined, they suggest a pattern of contractual back-to-back undertakings anchored to attestable technical baselines: each upstream party (model provider, framework maintainer, MCP-server operator) warrants a signed, versioned manifest of what it supplies (weight hashes, tool descriptions, guardrail configuration), undertakes to notify changes before they take effect, and answers for deviations from the attested baseline, while the integrating provider remains answerable for the composition itself and for detecting drift against the agent-aware SBOM of Table 2. On this pattern, the party whose attested artefact mutated answers for the mutation and the integrator answers for failing to detect it, an allocation that tracks both the CRA's due-diligence logic and the AI Act's rule that whoever substantially modifies a system becomes its provider (Article 25(1)). What contract cannot supply is reach: dynamically discovered servers with which the provider has no privity, and open-source components distributed outside any commercial relationship, fall outside the pattern, which is why we regard a regulatory extension of the due-diligence duty down the chain, rather than contract alone, as the direction harmonised standards or future amendment should take.

Open weights break downstream duties: Update distribution, incident monitoring, and weight protection presuppose a provider who retains control; for open-weight releases these duties are structurally unenforceable downstream, and the open technical problems catalogued by Casper et al. [21] translate directly into open legal ones, only partially relieved by the Act's open-source carve-outs.

Memory, minimisation, and the limits of unlearning: Agents accumulate personal data in memories and traces; erasure duties under the GDPR [46] and CRA deletion

requirements meet the technical reality that machine unlearning does not reliably remove information or its influence from models [49]. Unlearning research motivated by trustworthy-AI and delete-culture arguments [50, 51] is advancing, but compliance architectures should not currently promise model-level forgetting they cannot verify; segregating personal data into erasable stores outside the weights is the defensible pattern.

9 Conclusion

The EU has legislated cybersecurity outcomes for AI twice over (once through the AI Act's essential requirements and GPAI duties, once through the CRA's product regime) and has coupled the two through a deemed-compliance bridge. For LLM-based autonomous agents, whose defining property is that anyone who can write into their context can, absent countermeasures, act with their authority, these outcome duties are exacting but silent on mechanism. This article converted that silence into an explicit, testable structure: ten empirically grounded threat classes, an atom-by-atom decomposition of both regulation's cybersecurity provisions, a control mapping specific to agent architectures, and, for every control, the evidence artefact that conformity assessment and market surveillance will consume. Three findings stand out. The obligations most enforceable today are those the law names (the Article 15(5) attack families), while the empirically dominant agent attacks, indirect injection and tool poisoning, are reachable only through general clauses whose content harmonised standards have yet to fix. The CRA, not the AI Act, is the instrument that reaches most agent software, and its September 2026 reporting regime will surface agent vulnerabilities at Union level well before design duties bind. And because both regimes enforce through artefacts, evidence integrity (tamper-evident traces, signed configurations, agent-aware SBOMs) is not adjacent to compliance but constitutive of it. The mapping offered here is an interim baseline, intended to be superseded by harmonised standards and to be portable to converging regimes beyond the Union; until then, it gives providers, auditors, and authorities a shared answer to the question both regulations pose but neither answers: what, concretely, must an agent's security look like.

Author contributions A.O: conceptualisation, methodology, analysis, writing the original draft, review and editing.

Funding The author(s) declare that no funds, grants, or other support were received during the preparation of this manuscript.

Data availability No datasets were generated or analysed during the current study.

Declarations

Conflict of interest The authors have no relevant financial or non-financial interests to disclose.

Ethics approval and consent Not applicable. This article is a doctrinal and analytical study; no human participants, animals, or personal data were involved.

Open Access This article is licensed under a Creative Commons Attribution 4.0 International License, which permits use, sharing, adaptation, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if changes were made. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit <http://creativecommons.org/licenses/by/4.0/>.

References

1. Gulyamov, S., Gulyamov, S., Rodionov, A., Khursanov, R., Mekhmonov, K., Babaev, D., Rakhimjonov, A.: Prompt injection attacks in large language models and AI agent systems: a comprehensive review of vulnerabilities, attack vectors, and defense mechanisms. *Information* **17**(1), 54 (2026). <https://doi.org/10.3390/info17010054>
2. Weil, G.: Abnormally dangerous algorithms: the case for strict liability at the AI frontier. SSRN Preprint. (2026). <https://doi.org/10.2139/ssrn.6588958>
3. Chakrabarty, P.K.: Adversarial attacks on agentic AI systems: mechanisms, impacts, and defense strategies. *Int. J. Sci. Res. (IJSR)*. (2025). <https://doi.org/10.21275/SR25417074844>
4. Pandey, D., Manchanda, S.: Securing autonomous AI agents: a reference architecture for data protection in the agentic AI era. SSRN Prepr. (2026). <https://doi.org/10.2139/ssrn.6691718>
5. European Parliament, Council of the European Union: Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act). OJ L, 2024/1689, 12.7.2024. <http://data.europa.eu/eli/reg/2024/1689/oj>
6. European Parliament, Council of the European Union: Regulation (EU) 2024/2847 on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act). OJ L, 2024/2847, 20.11.2024. <http://data.europa.eu/eli/reg/2024/2847/oj>
7. Novelli, C., Casolari, F., Hacker, P., Spedicato, G., Floridi, L.: Generative AI in EU law: liability, privacy, intellectual property, and cybersecurity. *Comput. Law Secur. Rev.* **1**(55), 106066 (2024). <https://doi.org/10.2139/ssrn.4694565>
8. Yeung, K.: Can risks to fundamental rights arising from AI systems be 'managed' alongside health and safety risks? implementing article 9 of the EU AI act. SSRN Prepr. (2025). <https://doi.org/10.2139/ssrn.5560783>
9. Canavese, D., Ferreira, A., Laborde, R., Kandi, M.A.: Artificial intelligence systems in the European Union: guidelines and architectures for compliance-by-design. SSRN Prepr. (2024). <https://doi.org/10.2139/ssrn.5037706>
10. Madkour, N., Newman, J., Raman, D., Jackson, K., Murphy, E.R., Yuan, C.: Agentic AI risk-management standards profile. UC Berkeley Center for Long-Term Cybersecurity; SSRN preprint (2026). <https://doi.org/10.2139/ssrn.6276998>

11. European Commission: Proposal for targeted amendments to Regulation (EU) 2024/1689 (Digital Omnibus on AI). COM (2025) 836 final, 19 November 2025. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng>
12. Chen, M.L.: Frontier AI safety laws and Chinese AI companies: applicability and enforcement. SSRN Prepr. (2026). <https://doi.org/10.2139/ssrn.6106566>
13. European Commission, AI Office: General-Purpose AI Code of Practice (2025). <https://digital-strategy.ec.europa.eu/en/policies/contents-code-gpai>
14. European Parliament, Council of the European Union: Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union (NIS 2 Directive). OJ L 333, 27.12.2022, 80–152. <http://data.europa.eu/eli/dir/2022/2555/oj>
15. Eckhardt, P., Kotovskaia, A.: The EU's cybersecurity framework: the interplay between the Cyber resilience act and the NIS 2 directive. *Int. Cybersec. Law Rev.* **4**(2), 147–164 (2023). <https://doi.org/10.1365/s43439-023-00084-z>
16. Shaffique, M.R.: Cyber Resilience Act 2022: A silver bullet for cybersecurity of IoT devices or a shot in the dark? *Comput. Law Secur. Rev.* **54**, 106009 (2024). <https://doi.org/10.1016/j.clsr.2024.106009>
17. European Commission: Commission Implementing Decision on a standardisation request to CEN and CENELEC in support of Union policy on artificial intelligence. C (2023) 3215 final, 22 May 2023. [https://ec.europa.eu/transparency/documents-register/detail?ref=C\(2023\)3215&lang=en](https://ec.europa.eu/transparency/documents-register/detail?ref=C(2023)3215&lang=en)
18. Kaminski, M.E.: The developing law of AI: a turn to risk regulation. *Lawfare. The Digital Social Contract paper series* (2023). <https://doi.org/10.2139/ssrn.4692562>
19. Novelli, C., Casolari, F., Rotolo, A., Taddeo, M., Floridi, L.: AI risk assessment: a scenario-based, proportional methodology for the AI Act. *Digit. Soc.* **3**(1), 13 (2024). <https://doi.org/10.2139/ssrn.4464783>
20. Uuk, R., Brouwer, A., Schreier, T., Dreksler, N., Pulignano, V., Bommasani, R.: Effective mitigations for systemic risks from general-purpose AI. SSRN Prepr. (2024). <https://doi.org/10.2139/ssrn.5021463>
21. Casper, S., O'Brien, K., Longpre, S., Seger, E., Klyman, K., Bommasani, R., et al.: Open technical problems in open-weight AI model risk management. *Trans. Mach. Learn. Res.* (2026). <https://doi.org/10.2139/ssrn.5705186>
22. Call, C.: Adapting the NIST cybersecurity framework for artificial intelligence risk: a critical review of the cyber AI profile. SSRN Prepr. (2026). <https://doi.org/10.2139/ssrn.7144438>
23. Sharma, S.: Control and governance of generative and agentic AI: an AIS lifecycle framework for privacy and security. SSRN Prepr. (2026). <https://doi.org/10.2139/ssrn.6641378>
24. Schwarcz, D., Wolff, J.: The limits of regulating AI safety through liability and insurance: lessons from cybersecurity. *Fordham Law Rev.* **95** (forthcoming, 2026). <https://doi.org/10.2139/ssrn.5411062>
25. Caroli, L.: The great convergence: how frontier AI governance is coming together even in the U.S. SSRN preprint (2025). <https://doi.org/10.2139/ssrn.5886882>
26. Arbel, Y., Tokson, M., Lin, A.: Systemic regulation of artificial intelligence. *Ariz. State Law J.* **56**, 545 (2024). https://scholars.hip.law.ua.edu/cgi/viewcontent.cgi?article=1804&context=fac_articles
27. OWASP Foundation: OWASP Top 10 for LLM Applications. version 2025 (2025). <https://genai.owasp.org>
28. MITRE Corporation: MITRE ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems. <https://atlas.mitre.org>. Accessed August (2026)
29. National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST AI 100–1 (2023). <https://doi.org/10.6028/NIST.AI.100-1>
30. Ai, N.: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile. NIST Trustworthy and Responsible AI Gaithersburg, MD, USA (2024)
31. International Organization for Standardization: ISO/IEC 42001:2023, Information technology— Artificial intelligence— Management system. ISO, Geneva (2023). <https://www.iso.org/standard/42001>
32. Pathade, C., Dhiman, V., Ahmad, S.: Jailbreak-as-a-service: the emerging threat landscape. SSRN Prepr. (2026). <https://doi.org/10.2139/ssrn.6065410>
33. Li, X., Lao, M., Du, C., Feng, Y., Du, X., Bai, L., Guo, Y.: TAD-SOB: enhancing jailbreaking attacks on LLMs via trajectory-aware dynamic suffix optimization with buffer. SSRN Prepr. (2026). <https://doi.org/10.2139/ssrn.6431925>
34. Lee, R.W., Jun, T.J., Lee, J.-M., Cho, S.I., Park, H.J., Suh, J.: Manipulating medical advice through stealth prompt injection in large language models: an experimental study on vulnerabilities and patient safety risks. SSRN Prepr. (2025). <https://doi.org/10.2139/ssrn.5284059>
35. Li, Z., Zeng, Y., Xia, P., Liu, L., Fu, Z., Li, B.: Large language models are good attackers: efficient and stealthy textual backdoor attacks. SSRN Prepr. (2025). <https://doi.org/10.2139/ssrn.5365101>
36. Qu, Y., Huang, S., Chen, X., Bai, T., Yao, Y.: An input-denoising-based defense against stealthy backdoor attacks in large language models for code. SSRN Prepr. (2024). <https://doi.org/10.2139/ssrn.4821388>
37. Pi, J., Luo, S., Pan, L., Yang, Y., Zhang, J.: Extracting privacy from text embeddings: a model inversion attack via semantic correction and low-frequency entities preservation. SSRN Prepr. (2026). <https://doi.org/10.2139/ssrn.6461162>
38. Pi, J., Luo, S., Pan, L., Xu, C., Zhang, J.: Stealing supervised fine-tuning samples: a data extraction attack driven by token modulation and loss ratio. SSRN Prepr. (2026). <https://doi.org/10.2139/ssrn.6502555>
39. Sivashanmugam, S.: Model inversion attacks on Llama 3: extracting PII from large language models. SSRN Prepr. (2025). <https://doi.org/10.2139/ssrn.5341233>
40. Teixeira, F., Pizzi, K., Olivier, R., Abad, A., Raj, B., Trancoso, I.: Exploring features for membership inference in ASR model auditing. SSRN Prepr. (2024). <https://doi.org/10.2139/ssrn.4937232>
41. Jedrzejewski, F., Thode, L., Gorschek, T., Fischbach, J., Mendez, D., Lavesson, N.: Adversarial machine learning in industry: a systematic literature review. SSRN Prepr. (2024). <https://doi.org/10.2139/ssrn.4737990>
42. Shima, H., Saengchote, K., Chakraborty, K., Wang, C., Khernam-nuai, W.: Adversarial attacks on machine learning-driven high-frequency trading models. SSRN Prepr. (2025). <https://doi.org/10.2139/ssrn.5367043>
43. Kasyap, H., Tripathy, S.: Beyond data poisoning in federated learning. SSRN Prepr. (2023). <https://doi.org/10.2139/ssrn.4408355>
44. Raza, A., Li, S., Tran, K.P., Koehl, L., Tran, K.D.: Using anomaly detection to detect poisoning attacks in federated learning applications. SSRN Prepr. (2024). <https://doi.org/10.2139/ssrn.4811423>
45. Rane, N.L., Mallick, S.K., Rane, J.: Adversarial machine learning for cybersecurity resilience and network security enhancement (ch. 10). Deep Science Publishing (2025). <https://doi.org/10.70593/978-93-7185-143-5>
46. European Parliament, Council of the European Union: Regulation (EU) 2016/679 (General Data Protection Regulation). OJ L 119, 4.5.2016, pp. 1–88. <http://data.europa.eu/eli/reg/2016/679/oj>
47. Wills, P.: Regulatory supervision of frontier AI developers. SSRN Prepr. (2025). <https://doi.org/10.2139/ssrn.5122871>
48. Vuletić, I., Petrašević, T.: Is it time to consider EU criminal law rules on robotics? *Croat. Yearb. Eur. Law Policy* **16**(1), 225–244 (2020). <https://doi.org/10.3935/cyelp.16.2020.371>

49. Cooper, A.F., Choquette-Choo, C.A., Bogen, M., Jagielski, M., Filippova, K., Liu, K.Z., et al.: Machine unlearning doesn't do what you think: lessons for generative AI policy, research, and practice. SSRN Prepr. (2025). <https://doi.org/10.2139/ssrn.5060253>
50. Hine, E., Novelli, C., Taddeo, M., Floridi, L.: Supporting trustworthy AI through machine unlearning. *Sci. Eng. Ethics* **30**(5) (2024). <https://doi.org/10.2139/ssrn.4643518>
51. Floridi, L.: Machine unlearning: its nature, scope, and importance for a “delete culture” L. Floridi. *Philos. Technol.* **36**(2), 42 (2023)

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.